



DESCRIPCIÓN DE PUESTO DE TRABAJO
RESPONSABLE SEGURIDAD DE LA INFORMACIÓN (CISO)

DPT01 Rev.01

USO INTERNO

MISIÓN

Definición, implementación y supervisión de estrategias, políticas, controles y procedimientos de seguridad para proteger la información y los activos tecnológicos de la organización de amenazas tanto internas como externas a fin de que todos los datos estén protegidos adecuadamente y cumplan con las normativas de privacidad y seguridad relevantes y los compromisos contractuales.

Dependencia

- Dirección General

Autoridad

- Todo el personal de la organización, en temas de seguridad de la información

FUNCIONES Y RESPONSABILIDADES

- **Gestión Estratégica de la Seguridad**

- Definir y mantener la estrategia corporativa de seguridad de la información alineada con los objetivos del negocio.
- Desarrollar, actualizar e implementar el SGSI de la organización (ISO 27001, ENS u otros).
- Establecer políticas, normas y procedimientos de seguridad.
- Asegurar que el Sistema de Gestión de Seguridad de la Información es conforme con las normas de referencia (ISO 27001, ENS).
- Colaborar con la Dirección en la determinación de objetivos de seguridad de la información.

- **Gobierno y Gestión de Riesgos**

- Realizar análisis y gestión de riesgos de la información de forma periódica.
- Coordinar evaluaciones de impacto, análisis de brechas y auditorías internas/externas.
- Supervisar planes de tratamiento y mitigación de riesgos.

- **Protección Tecnológica**

- Supervisar la implementación y mantenimiento de controles técnicos:
 - Gestión de accesos e identidades
 - Ciberseguridad perimetral y de red
 - Gestión de vulnerabilidades
 - Seguridad en la nube
 - Protección de datos (DLP, cifrado)
 - Monitorización y respuesta a incidentes
- Promover y supervisar la realización de auditorías de seguridad de los sistemas y redes.

- **Gestión de Incidentes**

- Liderar la gestión y respuesta ante incidentes de seguridad.
- Coordinar investigaciones forenses cuando sea necesario.
- Elaborar informes ejecutivos sobre incidentes y lecciones aprendidas.
- Coordinar la comunicación con las autoridades y CIRT de referencia.

- **Relación con Terceros y Cumplimiento**

- Asegurar el cumplimiento de normativas (ISO 27001, ENS, etc.).
- Gestionar contratos y acuerdos de seguridad con proveedores.

- Velar por la seguridad en la cadena de suministro (supply chain security).
- **Concienciación y Cultura de Seguridad**
 - Diseñar y coordinar programas de formación y concienciación para empleados.
 - Promover una cultura de seguridad en toda la organización.
- **Documentación y Reportes**
 - Preparar informes para la alta dirección.
 - Informar sobre el desempeño del Sistema de Gestión de Seguridad de la información y sobre las oportunidades de mejora.
 - Mantener documentación actualizada del SGSI, métricas y KPIs.

Estas funciones se complementan con las definidas para el Responsable de Seguridad en el marco del ENS según se contempla en el *D01 Política de Seguridad de la Información*.

Formación necesaria	• Titulación universitaria en Ingeniería Informática, Telecomunicaciones, Sistemas, Ciberseguridad o similar. • Se valoran estudios de posgrado en seguridad de la información o ciberseguridad.
Conocimientos deseables	• Norma ISO 27001 • Esquema Nacional de Seguridad (ENS) • Reglamento General de Protección de Datos (RGPD) • Requisitos legales de aplicación al sector • Gestión de riesgos • Arquitecturas de seguridad • Seguridad en redes y sistemas • Seguridad cloud (Azure, AWS, ...) • Gestión de incidentes y forense digital • Herramientas de SIEM, EDR, IDS/IPS, DLP
Experiencia requerida	• Experiencia 5 años en la gestión de sistemas de información • (Deseable) Experiencia de 3 años en seguridad de redes y sistemas
Habilidades	• Liderazgo y gestión de equipos • Capacidad analítica y resolución de problemas • Comunicación clara y efectiva • Toma de decisiones bajo presión • Visión estratégica • Capacidad comunicativa. • Planificación y organización.